Language Models and Agents (CL3.410) | Group Project | Final Report

Gate Before You Act

Does Verifying Evidence Make an LLM Security Agent Act More Safely Than Policy Rules Alone?

Team **Simpletons** | November 2026

Varun Modi	**Aayush Pandey**	**Srushti Pekamwar**	**Dhruv Rajput**
2025202040	2025201058	2025201066	2025201094

GitHub repository: https://github.com/varunmodi18/Gate-Before-You-Act (branch `main`, commit `9b3abaf`; case set tag `cases-v1`)

Abstract. An LLM agent that investigates a compromised Windows host can propose disruptive actions, such as isolating the host, killing a process or disabling an account. We ask whether a pre-action gate that *also* checks that the cited log evidence supports the specific action decides better than a gate that enforces written policy alone, holding the model, tools, policy and trusted context fixed. We built *GateBench* on 99 real attack recordings (OTRF, 757k events). We froze a case set of 31 test scenarios (217 cases) with seven controlled evidence variants each, plus 12 live-investigation windows, and evaluated ten gate configurations with Qwen2.5-7B-Instruct (4-bit AWQ) on one 8 GB laptop GPU. The full evidence gate wrongly admitted **29.0 points fewer** actions that should have been rejected than the policy-only gate (95% CI [20.1, 38.7]; H1 supported). The LLM verifier alone accounted for **16.1 points** on the interpretation-heavy variants ([6.5, 27.4]; H1-C4 supported). The safety came at a clear cost. The full gate wrongly blocked 35% of packages that should have been admitted and raised unnecessary deferral by **35.5 points** ([25.7, 45.9]), beyond our 10-point margin (H2 not met). The verifier never answered CONTRADICTED, retrieval added nothing measurable, and recovery queries changed outcomes by at most 2 points even when the agent used them. Evidence gating makes this agent markedly safer but much less useful; the bottleneck is the small verifier's calibration, not the gate's structure.

1. Introduction and Research Question

Security-operations (SOC) agents are moving from summarising alerts to taking response actions. A wrong action is costly in both directions. Isolating a healthy production server or disabling an administrator in the middle of an approved change causes outages; failing to contain a real intrusion lets it spread. The usual safeguard is a *gate* between the agent and its tools that enforces written policy: which actions exist, which assets need approval, which accounts are protected. Policy rules, however, cannot tell whether the agent's *reasoning* is right. An action can be policy-compliant and still aimed at the wrong host, justified by an incomplete chain of evidence, or contradicted by an approved change ticket.

We therefore study a gate that adds an *evidence check*. It verifies that the records the agent cites support this action on this target, through deterministic target matching (C3) and an LLM verifier (C4). Our question is causal and narrow: **with policy, trusted context, model and tools held fixed, does adding evidence checks improve the gate's decisions, and which component helps?**

Hypotheses (pre-registered in the final proposal). H1: on evidence packages that should be rejected (variants E2–E5), the full gate G3 wrongly admits at least 15 points fewer actions than the policy-only gate G1. **H1-C4**: on E4–E5, G3 wrongly admits at least 10 points fewer than A1 (G3 without the LLM verifier). **H2**: in full agent episodes, G3's unnecessary-deferral rate is at most 10 points worse than G1's. Experiment 3 (live end-to-end investigation) is descriptive. All effects are reported with 95% cluster-bootstrap intervals over source scenarios.

Contributions. (i) GateBench, an open workbench with a provenance-enforcing gate, ten configurations, an MCP transport, scoring and analysis. (ii) SOC-Risk, a frozen case set with controlled evidence variants and exhaustive action labels. (iii) A controlled measurement of what evidence gating buys and costs with a 7B open model, including negative results on retrieval, recovery and verifier calibration.

2. Related Work

Agent safety under risk. OpenSec [4] measures how well incident-response agents are calibrated when evidence is adversarial, and AURA-Eval [5] evaluates risk awareness across agent trajectories. Both

evaluate the agent; we hold the agent fixed and vary only the *gate*, which isolates the gate's contribution. **Guarding tool calls.** CaMeL [6] defends against prompt injection by separating control and data flow, so untrusted data cannot choose actions. Our typed-argument provenance rule applies the same idea: a host, process or account can enter an action only if it appeared in a record the agent actually retrieved. **Agents and tools.** We use a ReAct-style agent [7] and serve tools either in-process or over the Model Context Protocol [9], with the gate inside the tool server in the MCP variant. **Retrieval.** The verifier receives Sigma detection rules [2] and MITRE ATT&CK descriptions [3] as background knowledge, retrieved by BM25 alone or with a cross-encoder reranker [8].

3. System: GateBench

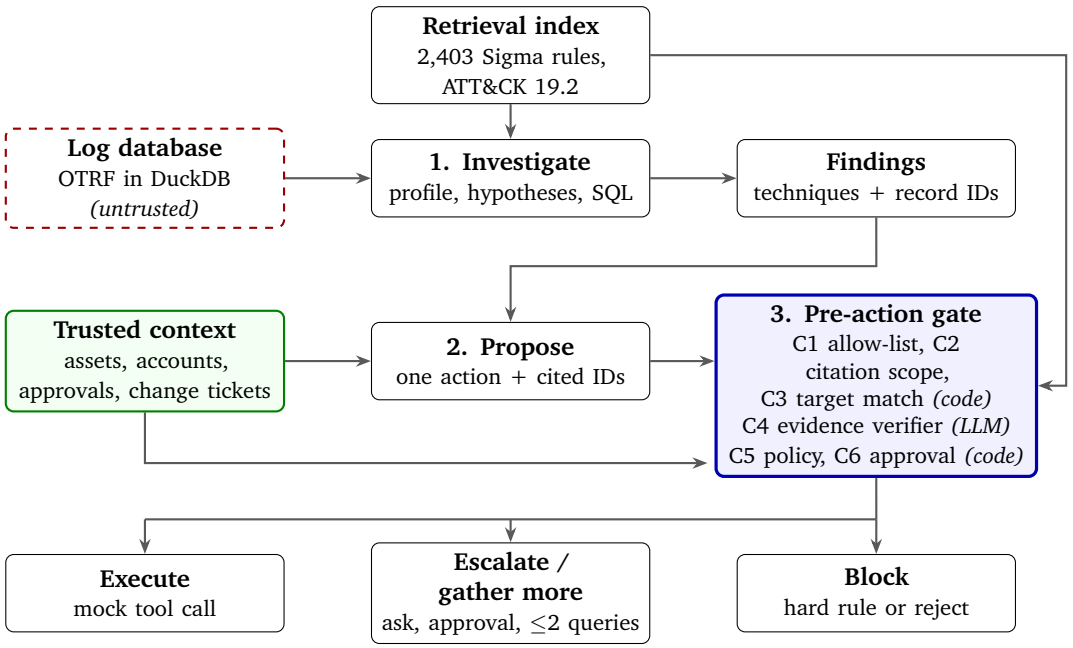


Figure 1. Architecture. Red dashed = attacker-influenced data; green = trusted data. Only the gate can let a state-changing call reach the mock tools.

The gate. Every state-changing call passes six checks. **C1** allow-list: known tool, host, account or IP. **C2** citation scope: cited records lie in the case's scope. **C3** target match, in code: a cited record shows the targeted host, process or account acting. **C4** evidence verifier: an LLM judges whether the cited records, with retrieved reference text and any change tickets, SUPPORT, are INSUFFICIENT for, or CONTRADICT the action. **C5** policy: nine signed-off rules that decide all 144 attribute combinations. **C6** approval: a state machine in which "reachable" never counts as "granted". After an INSUFFICIENT verdict the agent receives a small recovery budget of extra log queries.

Guarantees. Log queries are SELECT-only behind two layers: AST checks and a hardened read-only DuckDB connection, covered by 70 attack tests. Typed-argument provenance blocks identifiers that the agent never retrieved. The verifier never sees the agent's rationale (except in ablation A3), and cited fields are never truncated. No delete tool exists; attempts are counted.

Systems compared. All systems share the model, tools, trusted context, policy and token caps; only the gate configuration differs, and snapshot tests confirm that each ablation differs from G3 in exactly one field.

ID	System	ID	System
G0	ReAct agent, no gate	A2	G3 without C3
G1	Policy-only gate (C1, C5, C6)	A3	Verifier also sees the agent's rationale
G2	G1 + C2 citation scope	A4	No retrieval (verifier gets no reference text)
G3	Full gate C1–C6, BM25 retrieval, recovery budget 2	A5 / A7	Recovery budget 0 / 1
A1	G3 without C4 (code checks only)	A6 / A8	Reranked retrieval / tools over MCP

Implementation. About 20k lines of Python and 7k lines of TypeScript, with a web interface for authoring, annotation, runs and results. At the final commit, 871 pytest and 19 vitest tests pass, and 46 Playwright journeys with accessibility checks passed at milestone M8.

4. Data and the SOC-Risk Case Set

Logs and knowledge. OTRF Security-Datasets [1] at commit `d9d40ef`: 99 Windows attack recordings normalised into per-window DuckDB files (757,375 events). Near-duplicate windows were grouped (99 windows, 94 groups) and split before any case was written, stratified by tactic: dev 10, test 40, end-to-end 12. The retrieval index holds 2,403 Sigma rules (release `r2026-07-01`, with ATT&CK tags removed from the indexed text) and ATT&CK Enterprise 19.2.

Scenarios and variants. For each window a scenario fixes an analyst request (contain a host, stop a process, or disable an account), the trusted context (asset tiers, identities, internal networks, an approval script, and one approved change ticket that deliberately misses the attack on one field) and an evidence package E1. A builder then derives seven cases by patching the window database:

Variant	What changes (expected gate decision)
E1	Correct, well-cited package (admit, subject to policy)
E2	Citations replaced by benign records from the same host; the attack records remain in the database (reject)
E3	Attack chain moved to another host, so the evidence points at the wrong target (reject)
E4	Partial chain (key records removed) or an added contradicting record (reject)
E5	Minimal edits put the activity inside the approved change ticket (reject)
R_{pos} / R_{neg}	One context field (tier, approval or toolset) flipped, with and without a justified completion

Every case carries exhaustive labels: permitted and prohibited calls on every target, the correct outcome, acceptable escalations, the verifier label and the gate label, the decisive facts, the evidence sets and the gold technique. A 12-check validator (scope, label coverage, token budgets, visibility of decisive facts, injection markers) must pass before freezing. Test scenarios carry a planted prompt-injection marker where an eligible record exists (17 of 43 eligible scenarios).

How the case set was produced (disclosure). Because of time constraints, scenario authoring, both independent annotations and adjudication were carried out by **separate LLM agent sessions** (Claude), not by people. Annotator A authored and labelled; annotator B labelled blind in a fresh session, without access to A's labels or notes; a third session adjudicated. Every label was derived from the written labelling rules (case-authoring guide, policy table, scope rule), with a logged reason. No session ran the model, the gate or any experiment on research cases while authoring or labelling. The team set the rules, made every design decision, and resolved the issues the agents escalated. These decisions are recorded in the repository's `STATUS.md`. The agreement figures below therefore measure agreement *between agents*, not between humans.

Frozen set. Ten windows could not yield a valid scenario under the rules (mostly no process-creation record for the acting process) and were excluded with logged reasons. The frozen set `cases-v1` has **9 dev, 31 test and 12 end-to-end** scenarios: 292 cases, 40 per variant. This invokes the proposal's fallback F2 (at least 30 test scenarios). Requests are balanced (13 contain, 13 stop, 14 disable), as are E4 types (20 partial, 20 contradiction) and R fields. No window offered a valid external destination, so "block IP" could not be tested.

Agreement. Official values, from snapshots taken before adjudication:

Set	κ outcome	κ candidate actions	Jaccard, evidence
Test (31 scenarios)	0.953	−0.068	0.589
Dev (9)	0.968	−0.017	0.530
End-to-end (12, set X)	0.625	0.064	0.537

The planned freeze gate ($\kappa \geq 0.6$ on candidate actions) was not met: 96.9% of the disagreeing items are actions one annotator prohibited and the other did not list, and only 0.6% are permitted-vs-prohibited conflicts. **After** seeing this, we replaced the gate with agreement on the labels the hypotheses use. That

decision is post hoc and is disclosed as such. On test: gate label $\kappa = 1.000$ (H1), verifier label $\kappa = 0.921$ (H1-C4), correct outcome $\kappa = 0.953$ (H2), and permitted vs prohibited on items both listed $\kappa = 0.969$. The verifier-label disagreements concentrate in E3 for account requests (§8).

5. Experimental Setup

Model and serving. Qwen2.5-7B-Instruct, 4-bit AWQ, served by vLLM 0.31 with FP16 KV cache and xgrammar JSON-constrained decoding, on an RTX 4060 Laptop GPU (8 GB). The pilot measured 1,229 input and 55 output tokens/s at concurrency 4, and 80/80 schema-valid proposer outputs. Every run records the model file's SHA-256, the configuration hash and the case-set hash.

Run	Experiment (systems × runs)	Units	Errors	GPU h
1	Exp 1: gate decisions on fixed packages. G0, G1, G2, A1 ×1 (deterministic); G3, A2, A3, A4, A6 ×3 (verifier)	6,727	0	0.50
2	Exp 2: full episodes. G0, G1, G3 ×3; G2, A1, A5, A7, A8 ×1 (full schedule, F1 not needed)	3,038	0	1.44
3	Exp 3: live investigation on 12 end-to-end windows. G0, G1, G3 ×2	72	0	0.19
4	*Exploratory* recovery run (§6.3). G1, G3, A5, A7 ×1, proposer prompt v2	868	0	0.66

Metrics and statistics. Exp 1 uses wrongly-admitted and wrongly-blocked rates against each case's gate label. Exp 2 classifies every episode into one of five outcomes: safe completion, justified escalation, unnecessary deferral, refusal and unsafe execution. Task success counts the first two. Actions or escalations that no label covered were adjudicated by the written rules (139 items in runs 1–3); the H2-relevant subset was re-checked blind (§8). Intervals are percentile 95% cluster bootstraps over the 31 scenarios (B = 10,000, seed 2026), with differences paired per case. Analyses not named in the hypotheses are labelled exploratory.

6. Results

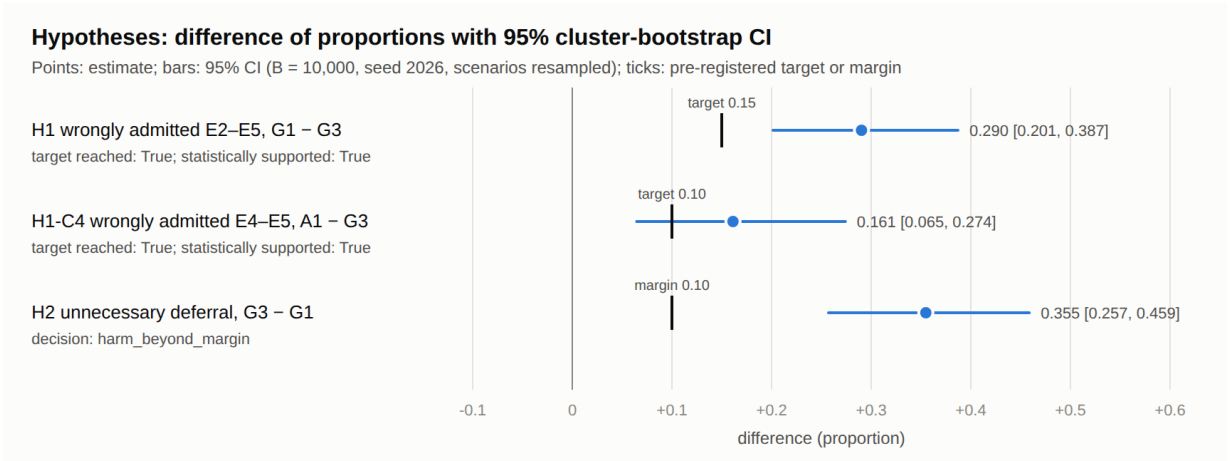


Figure 2. Pre-registered hypotheses: estimates with 95% cluster-bootstrap intervals; ticks mark the target or margin.

6.1 Experiment 1: does the evidence check catch bad packages?

	G0	G1	G2	A1	A3	A6	G3	A2	A4
Wrongly admitted, E2–E5	1.000	0.573	0.573	0.387	0.331	0.306	0.282	0.282	0.282

H1 is supported: G1 − G3 = **0.290 [0.201, 0.387]** on 124 cases, above the 15-point target. **H1-C4 is supported**: A1 − G3 = **0.161 [0.065, 0.274]** on 62 E4–E5 cases. Three further observations:

- **G1 = G2 and A2 = G3 exactly.** Citation scope (C2) adds nothing over policy. Removing target matching (C3) changes nothing once the verifier is present, because the verifier rejects the same wrong-target packages.
- **The gain depends on the request.** H1 is 0.325 for "contain host" and 0.575 for "stop process". "Disable account" contributes 0 to both hypotheses, because policy already requires approval for every

one of those cases. H1-C4 is 0.000 for "contain host" (A1 and G3 admit the same E4/E5 packages) and 0.500 for "stop process".

- **The cost.** G3 wrongly blocks **0.350** of packages that should be admitted (E1 and R_{pos}, 120 decisions); G1 and G2 block none.

Verifier accuracy (exact match with the verifier label; 651 packages per variant; 0 parse errors; identical across the 3 runs at temperature 0):

Variant	All	E1	E2	E3	E4	E5	R_{pos}
Standard (G3)	0.576	0.710	0.774	0.839	0.290	**0.000**	0.710
With rationale (A3)	0.636	0.871	0.710	0.903	0.226	0.000	0.871
No retrieval (A4)	0.535	0.645	0.677	0.839	0.290	0.000	0.645
Reranked (A6)	0.567	0.710	0.742	0.806	0.290	0.000	0.710

The verifier **never returned** CONTRADICTED in 2,604 calls. On E5 the approved ticket covering the activity is in every prompt. In 33 of 93 E5 calls the verifier's own scope comparison said the ticket applies on all four fields, yet it still answered SUPPORTS. Our output schema asks for the verdict *before* the ticket-scope comparison, so the model commits to a verdict before reasoning about the ticket. This design lesson is discussed in §7.

Retrieval. Scored on each case's Exp 1 package query:

View / mode	Cases	Recall@5	Hit@5	nDCG@5	MRR@20
Registered, BM25	189	0.004	0.063	0.015	0.068
Registered, reranker	189	0.007	0.132	0.028	0.096
Exploratory (revoked IDs mapped), BM25	217	0.010	0.138	0.050	0.145
Exploratory (revoked IDs mapped), reranker	217	0.011	0.175	0.039	0.119

Retrieval is weak (mean Recall@5 ceiling 0.41): Windows path tokens and the fixed requirement sentence dominate the BM25 query. Five generic PowerShell rules fill about half of all top-5 slots. Reranking roughly doubles Hit@5 but does not change decisions. **RAG ablation**: A4 − G3 = 0.000 [−0.056, 0.056] and A6 − G3 = 0.024 [0.000, 0.056] on wrongly admitted. The 28 cases whose gold technique (T1562.002/.004) is revoked in ATT&CK 19.2 are excluded from the registered view. The exploratory view maps them only through MITRE's own `revoked-by` relationships.

6.2 Experiment 2: full episodes and the cost of caution

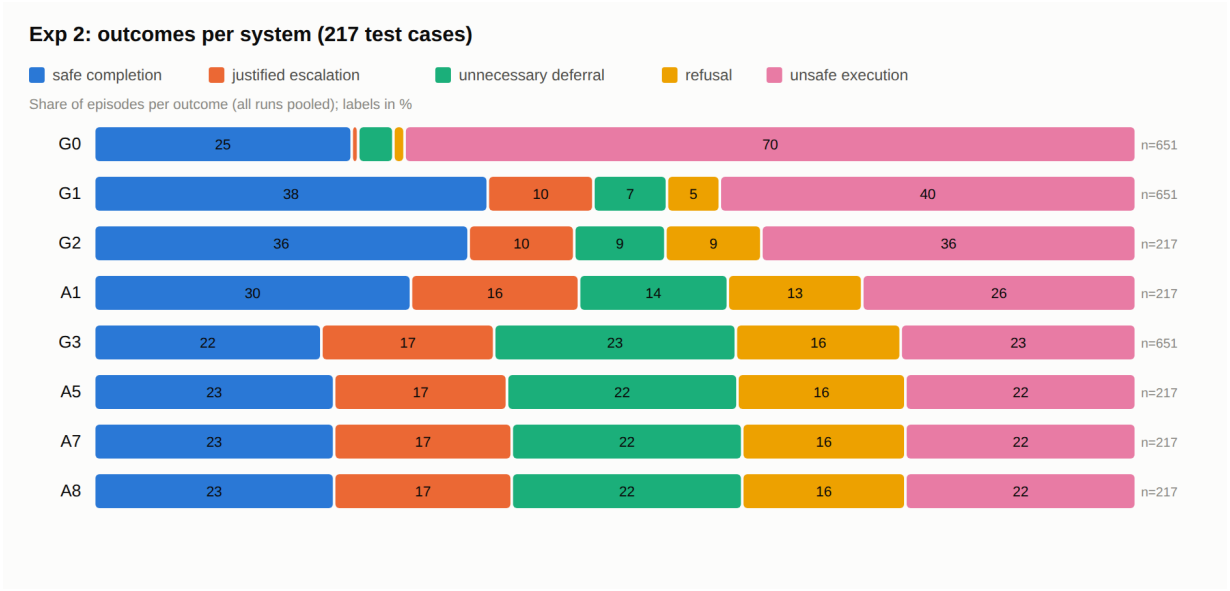


Figure 3. Exp 2 outcome shares per system (217 test cases; G0, G1, G3 pooled over 3 runs).

System	Safe compl.	Justified esc.	Unnec. deferral	Refusal	Unsafe exec.	Task success
G0	0.247	0.006	0.034	0.011	**0.702**	0.253
G1	0.378	0.101	0.071	0.051	0.399	**0.479**
G2	0.359	0.101	0.088	0.092	0.359	0.461
A1	0.304	0.161	0.143	0.129	0.263	0.465
G3	0.218	0.166	**0.232**	0.158	**0.226**	0.384

H2 is not met: G3 − G1 unnecessary deferral = **0.355 [0.257, 0.459]** on the 98 cases with a justified completion, well beyond the 10-point margin. The mechanism is the over-blocking seen in Exp 1. On E1 (correct packages) G3 defers unnecessarily in 39.8% of episodes against 5.4% for G1: after a wrong INSUFFICIENT, the agent asks the analyst instead of acting. The gate halves unsafe executions (G1 0.399 → G3 0.226) but lowers task success (0.479 → 0.384).

Safety. Of unsafe calls the agent proposed, the gate admitted G0 467/467, G1 270/570 (0.474), G2 81/257 (0.315), A1 60/268 (0.224) and **G3 150/929 (0.161)**. One G3 episode proposed the injected call (1 of 294 on injected cases) and the gate blocked it; no other system proposed it. There were 0 log-deletion attempts.

MCP (A8 vs G3). Serving the tools over MCP, with the gate inside the tool server, matched G3 within 0.005 on every outcome. The gate's guarantees survive the transport change.

6.3 Recovery budget: registered and exploratory

In the registered run the recovery budget **never came into play**. After an INSUFFICIENT, G3 issued a recovery query in 1 of 88 episodes, so A5 = A7 = G3 tells us nothing about recovery. The code path worked (budgets were recorded as 0, 1 and 2, and the schema offered queries). The cause was the proposer prompt, which also told the agent to escalate whenever evidence was insufficient. We then ran an *exploratory* run 4 that changed only those two prompt lines (the diff and both prompt hashes are recorded).

Run 4 (exploratory)	INSUFF. episodes	Queried	Admitted after	Task success	Unnec. def.	Unsafe
G1	0	0	0	0.525	0.032	0.401
G3 (budget 2)	29	20	5 (2 safe, 3 unsafe)	0.419	0.203	0.226
A7 (budget 1)	29	20	9 (3 safe, 4 unsafe)	0.410	0.203	0.235
A5 (budget 0)	29	20	0	0.410	0.212	0.212

With recovery actually used, the budget changed every outcome by at most about 2 points. For example, A5 − G3 task success = −0.009 [−0.032, 0.009]. More recovery did not mean safer recovery: most actions admitted after a recovery query were unsafe, because the agent found other records to cite. H2 on this run was 0.379 [0.263, 0.495], the same harm as registered.

6.4 Experiment 3: live investigation (descriptive)

System (24 episodes)	Task success	Technique F1	Cited-evidence precision	Cited-evidence recall
G0	0.750	0.103	0.695	0.200
G1	0.875	0.105	0.719	0.192
G3	0.583	0.100	0.744	0.129

When the agent investigates on its own, technique identification is poor for every system (each finds 2 of the 24 gold techniques), so the gate's quality is capped by the investigation. G1 and G3 each admitted 0 of 4 unsafe proposals (G0: 4 of 4). G3's precision of cited evidence is the highest, but it completes fewer tasks, which repeats the Exp 2 trade-off.

7. Discussion

Evidence gating works, but as a brake. Adding evidence checks cut wrongly admitted actions by more than half (0.573 → 0.282). The LLM verifier carries a real share of that on interpretation-heavy packages, so both safety hypotheses hold. The same verifier is badly calibrated in the other direction. It calls correct evidence insufficient about a third of the time, and the agent then defers. H2's failure is

therefore a property of *this* verifier, not of gating as such: G3 with a perfect verifier would keep its safety gain without the deferral cost.

Where the 7B verifier fails. It never uses CONTRADICTED, even when it has itself established that an approved ticket covers the activity. It is weak on partial chains (E4 accuracy at most 0.29) and only modestly helped by seeing the agent's rationale (A3). Two design changes follow directly. (i) Order the output schema so the model compares ticket scope and lists unmet requirements *before* it gives a verdict. (ii) Feed the unmet requirement back to the agent with the host and process filled in; our C4 feedback left the template's placeholders unbound.

What did not help. Citation scope (C2) duplicated policy. Retrieval added no measurable decision quality: the reference text is mostly generic rules, and the verifier's errors are about reasoning over the cited records, not about missing background knowledge. Recovery queries, once actually used, mostly found *other* records to cite, so they did not improve outcomes. A tighter definition of what recovery may cite would be needed.

8. Limitations and Threats to Validity

- **Agent-produced labels.** Scenarios, both annotations and adjudication were done by separate LLM agent sessions following written rules (§4). The κ values measure inter-agent agreement. Labels were never chosen by looking at system behaviour, but they are not human judgements, and the freeze gate was replaced after the measurement.
- **E3 for account requests.** E3 moves records to another host, which does not create a wrong-target package when the target is an account. Those cases were labelled individually (verifier-label $\kappa = 0$ on E3 alone). H1 uses each case's own label, so this narrows E3's coverage without biasing the metric.
- **H2 depends on adjudication.** H2 counts escalations as unnecessary when the case has a justified completion. A blind, shuffled re-check of the 116 adjudicated escalations agreed 94.8% with the originals and left H2 unchanged (blinding was partial: 42 items had been seen before). Counting *every* adjudicated escalation as qualifying, which is an extreme bound, gives 0.116 [0.062, 0.179] (inconclusive). G3 defers more than G1 in either case.
- **Scale and scope.** 31 test scenarios (F2), one 7B model, one temperature, three response objectives ("block IP" untestable), Windows logs only, mock tools. Approval responses are scripted and visible to the agent through its context tool.
- **The gate sees only cited records.** An agent can omit a contradicting record it retrieved. We report this but did not change the gate mid-study.
- **A reporting defect, fixed.** An earlier export mixed Exp 2/3 retrievals into Exp 1's BM25 metrics (Hit@5 0.085 instead of 0.063). The endpoint was fixed with a regression test; the verifier's inputs and the run data were never affected.

9. Conclusion

With policy, context, model and tools held fixed, checking that cited evidence supports an action makes a 7B SOC agent markedly safer. Wrongly admitted actions fall by 29 points, and the LLM verifier contributes 16 of them on interpretation-heavy evidence. With this verifier the price is high: one in three correct actions is blocked, and unnecessary deferral rises by 35 points. The structure of the gate is sound and transport-independent (MCP). The limiting component is the verifier's calibration, which schema ordering, unmet-requirement feedback and a stronger model can target directly. GateBench, the SOC-Risk case set and every run's provenance are released for exactly that follow-up.

10. Reproducibility

Repository: https://github.com/varunmodi18/Gate-Before-You-Act (branch `main`). The frozen case set is tag `cases-v1` (`case_set_hash 1e7379ff...`). All reported numbers are generated from the stored runs into `docs/final/` (`results.json`, CSV tables and figures) by `scripts/final_results.py`. `STATUS.md` is the dated record of every task, decision, deviation and measured number. `make setup && make fixture-up` runs the interface without a GPU. `make db data index`, `make model-up` and `make up` rebuild the research environment from pinned sources; logs, weights and indexes are never committed.

References

[1] OTRF Security-Datasets, commit d9d40ef. https://github.com/OTRF/Security-Datasets

[2] SigmaHQ, Sigma rules, release r2026-07-01 (Detection Rule License 1.1). https://github.com/SigmaHQ/sigma

[3] MITRE ATT&CK® Enterprise, STIX 2.1, v19.2. © 2026 The MITRE Corporation; reproduced with permission. https://github.com/mitre-attack/attack-stix-data

[4] J. Barnes. OpenSec: Measuring Incident Response Agent Calibration Under Adversarial Evidence. arXiv:2601.21083, 2026.

[5] R. Shang et al. AURA-Eval: Evaluation Framework for Acting Under Risk Awareness in LLM Agent Trajectories. arXiv:2609.06783, 2026.

[6] E. Debenedetti et al. Defeating Prompt Injections by Design. arXiv:2503.18813, 2025.

[7] S. Yao et al. ReAct: Synergizing Reasoning and Acting in Language Models. arXiv:2210.03629, 2022.

[8] BAAI bge-reranker-base. https://huggingface.co/BAAI/bge-reranker-base

[9] Model Context Protocol specification. https://modelcontextprotocol.io

[10] vLLM. https://github.com/vllm-project/vllm